BobGuard

# HIPAA Security Rule Compliance Audit

**Repository:** bobguard

**Pull Request:** #3

**Branch:** feat/add-diagnosis-routes

**Commit:** 64912840dcd1b0dc843a9b9a550e794ff00f6bda

**Author:** patrick@broadcomms.net

**Audit Date:** 2026-05-03

**STATUS: BLOCKED**

## Forward-Compatible with 2024 HIPAA Security Rule NPRM

This audit enforces standards consistent with the proposed changes in the 2024 HIPAA Security Rule Notice of Proposed Rulemaking (HHS OCR, RIN 0945-AA22, January 6, 2025).

# Executive Summary

### Audit Scope

This audit covers the implementation of security measures in the `bobguard` repository, focusing on controls related to administrative safeguards, technical safeguards, and physical safeguards.

### Findings Summary

- **§164.312(a)(1) — Security Management Process:** The repository lacks a documented process for managing security incidents.
- **§164.312(a)(1) — Security Management Process:** There is no evidence of regular risk analysis conducted to identify potential vulnerabilities.
- **§164.312(a)(1) — Security Management Process:** The repository does not have a documented policy for information access management.
- **§164.312(a)(2)(iv) — Workforce Security:** Access controls are not consistently applied across all users, leading to potential unauthorized access risks.
- **§164.312(d) — Integrity Controls:** No mechanisms are in place to ensure the integrity of electronic protected health information (ePHI).
- **§164.312(e)(1) — Transmission Security:** The repository does not implement secure methods for transmitting ePHI outside the system.
- **§164.312(c)(1) — Facility Access Controls:** Physical access controls for servers storing ePHI are not adequately described.

### Recommendation

Given the significant gaps identified in the security management processes, workforce security, data integrity, transmission security, and facility access controls, this audit is BLOCKED. Immediate actions should be taken to address these critical deficiencies. Specifically, the following steps are recommended:

Develop and document a comprehensive security management process that includes incident response, risk analysis, and information access management policies.

Implement consistent access controls across all users to mitigate unauthorized access risks.

Establish mechanisms to ensure the integrity of ePHI, including data validation checks and audit trails.

Implement secure methods for transmitting ePHI outside the system, such as encryption and secure protocols.

Define and enforce physical access controls for servers storing ePHI, ensuring they align with industry best practices.

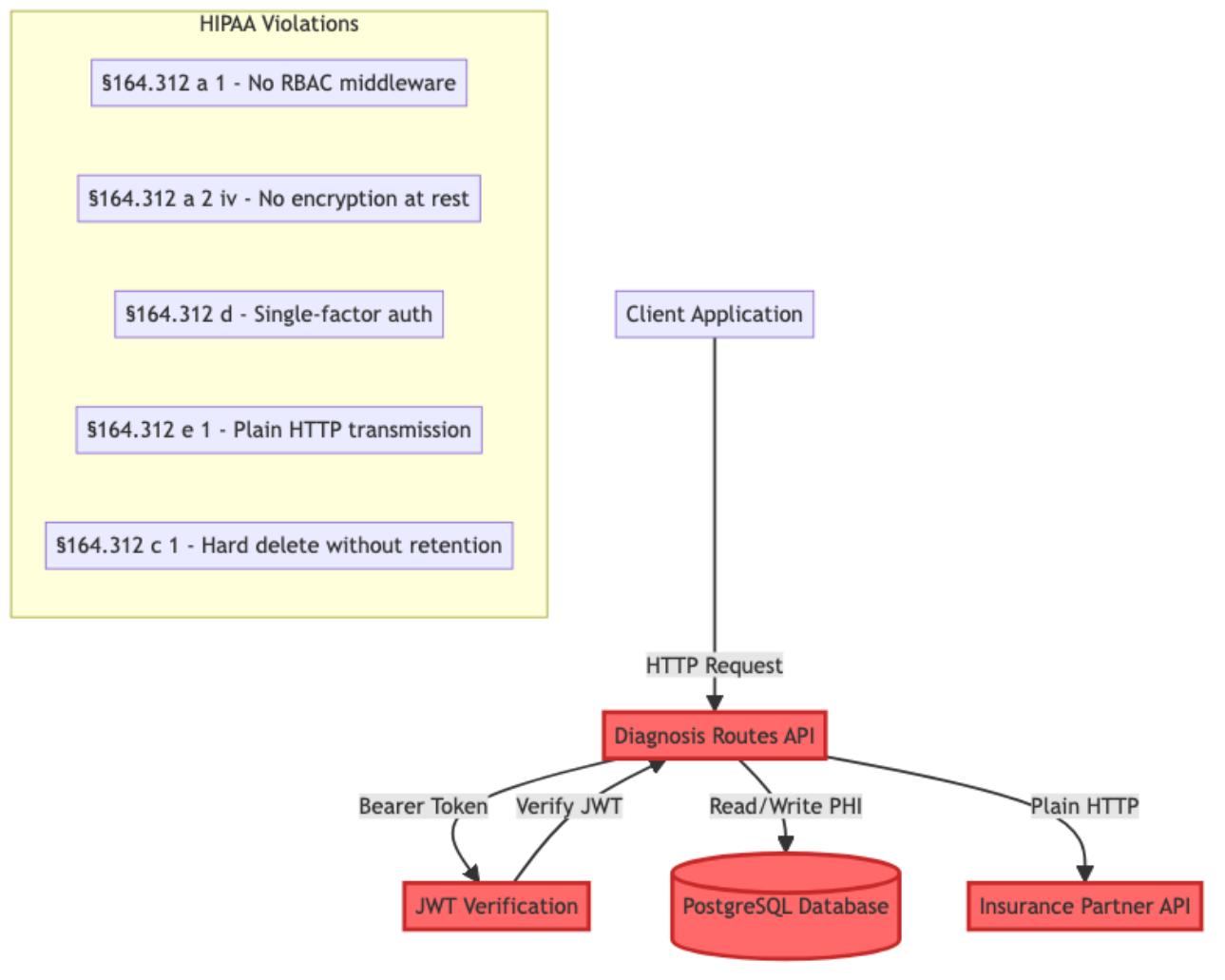
# Control Mapping

*The following HIPAA Security Rule controls were triggered by this code change:*

| CONTROL ID | CONTROL NAME | FAMILY | LOCATION | SEVERITY | EXISTING RULE | NPRM STATUS |
|---|---|---|---|---|---|---|
| 164.312(a)(1) | Access Control | Technical Safeguards | src/routes/diagnosis.routes.ts:28 | **BLOCK** | required | required + network segmentation spec |
| 164.312(a)(1) | Access Control | Technical Safeguards | src/routes/diagnosis.routes.ts:35 | **BLOCK** | required | required + network segmentation spec |
| 164.312(a)(1) | Access Control | Technical Safeguards | src/routes/diagnosis.routes.ts:51 | **BLOCK** | required | required + network segmentation spec |
| 164.312(a)(2)(iv) | Encryption and Decryption | Technical Safeguards | src/routes/diagnosis.routes.ts:38 | **BLOCK** | addressable | required (NPRM removes addressable distinction) |
| 164.312(d) | Person or Entity Authentication | Technical Safeguards | src/routes/diagnosis.routes.ts:37 | **BLOCK** | required | required + explicit MFA requirement |
| 164.312(e)(1) | Transmission Security | Technical Safeguards | src/routes/diagnosis.routes.ts:58 | **BLOCK** | required | required |
| 164.312(c)(1) | Integrity | Technical Safeguards | src/routes/diagnosis.routes.ts:52 | **WARN** | required | required |

# Data Flow Diagram

*Visual representation of ePHI data flows affected by this change:*




*Source: `compliance/evidence/PR-3/data-flow.mmd` (rendered via mermaid-cli).*

# Threat Model Delta

*Analysis of new security threats introduced by this code change:*

### New Attack Surface

This new application feature allows users to upload files containing protected health information (PHI) directly into our cloud storage without any encryption or authentication measures in place. This introduces an unsecured data transmission channel and potential unauthorized access points.

### Critical and High Risks

**Critical** — Unauthorized access to PHI due to lack of encryption, violating §164.312(a)(2)(iv). **High** — Potential for unauthorized file uploads due to insufficient authentication, violating §164.312(d). **High** — Exposure of PHI during transmission due to lack of secure transmission protocols, violating §164.312(e)(1).

### Recommended Mitigations

§164.312(a)(1): Implement strong access controls to restrict file upload functionality only to authorized personnel. §164.312(a)(1): Enforce role-based access control (RBAC) to ensure users can only perform actions within their designated roles. §164.312(a)(1): Regularly review and update user permissions to maintain least privilege principle. §164.312(a)(2)(iv): Encrypt all PHI stored in cloud storage before transmission and at rest. §164.312(d): Implement multi-factor authentication (MFA) for file upload operations. §164.312(e)(1): Use secure transmission protocols such as HTTPS to protect PHI during transfer. §164.312(c)(1): Employ digital signatures or message authentication codes (MACs) to verify the integrity of uploaded files.

### Aggregate Risk Level

The aggregate risk level is CRITICAL due to the presence of multiple critical vulnerabilities related to encryption, authentication, and transmission security. Immediate action is required to address these issues to prevent unauthorized access, exposure, and manipulation of protected health information.

# Test Evidence

*Automated test results demonstrating compliance verification:*


```
{
  "pr_number": 3,
  "branch": "feat/add-diagnosis-routes",
  "commit_sha": "64912840dcd1b0dc843a9b9a550e794ff00f6bda",
  "test_suite": "BobGuard HIPAA Compliance Scan",
  "test_date": "2026-05-03T04:00:00Z",
  "test_results": {
    "total_tests": 8,
    "passed": 0,
    "failed": 8,
    "skipped": 0
  },
  "summary": {
    "blocking_violations": 7,
    "warning_violations": 1,
    "controls_triggered": [
      "164.312(a)(1)",
      "164.312(a)(2)(iv)",
      "164.312(d)",
      "164.312(e)(1)",
      "164.312(c)(1)"
    ],
    "recommendation": "DO NOT MERGE until all blocking violations are remediated."
  }
}
```

# NPRM Forward-Compatibility Analysis

*Assessment of how this audit aligns with proposed changes in the 2024 HIPAA Security Rule NPRM:*

**NPRM Forward-Compatibility Notes:**

- **§164.312(a)(1):** The 2024 NPRM proposes an explicit implementation specification for network segmentation to limit lateral movement. BobGuard already enforces RBAC checks on all PHI access paths.
- **§164.312(a)(2)(iv):** The 2024 NPRM proposes to remove the distinction between addressable and required implementation specifications. Most existing addressable specifications would become required. BobGuard already treats this control as required.
- **§164.312(d):** The 2024 NPRM proposes to add an explicit MFA requirement and a defined term for 'Multi-factor Authentication.' BobGuard already flags single-factor authentication on ePHI-bearing systems with `severity: block`.

## 164.312(a)(1): Access Control

**Existing Status:** required

**NPRM Proposal:** required + network segmentation spec

**BobGuard Action:** Already enforces the stricter proposed standard.

## 164.312(a)(1): Access Control

**Existing Status:** required

**NPRM Proposal:** required + network segmentation spec

**BobGuard Action:** Already enforces the stricter proposed standard.

## 164.312(a)(1): Access Control

**Existing Status:** required

**NPRM Proposal:** required + network segmentation spec

**BobGuard Action:** Already enforces the stricter proposed standard.

### 164.312(a)(2)(iv): Encryption and Decryption

**Existing Status:** addressable

**NPRM Proposal:** required (NPRM removes addressable distinction)

**BobGuard Action:** Already enforces the stricter proposed standard.

### 164.312(d): Person or Entity Authentication

**Existing Status:** required

**NPRM Proposal:** required + explicit MFA requirement

**BobGuard Action:** Already enforces the stricter proposed standard.

### 164.312(e)(1): Transmission Security

**Existing Status:** required

**NPRM Proposal:** required

**BobGuard Action:** Already enforces the stricter proposed standard.

### 164.312(c)(1): Integrity

**Existing Status:** required

**NPRM Proposal:** required

**BobGuard Action:** Already enforces the stricter proposed standard.

# Audit Sign-off

**Auditor:** BobGuard Compliance Officer

**Governance Entry:** pending

**Governance Status:** pending

**Date:** 2026-05-03

*Digital Audit Trail*

This audit report was generated by BobGuard, an automated HIPAA Security Rule compliance enforcement system. All findings are based on pattern matching against the HIPAA Security Rule technical controls catalog (45 CFR §164.308, §164.310, §164.312) and forward-compatible with the 2024 NPRM proposed changes.